

中华人民共和国通信行业标准

YD/T ××××—××××

电信网和互联网应用程序接口数据安全技术要求和测试方法

Data security technical requirements and testing methods for API of telecom and Internet

[点击此处添加与国际标准一致性程度的标识]

(报批稿)

[××××]-[××]-[××]发布

[××××]-[××]-[××]实施

中华人民共和国工业和信息化部 发布

目 次

前 言..... II

1 范围..... 1

2 规范性引用文件..... 1

3 术语、定义和缩略语..... 1

 3.1 术语定义..... 1

 3.2 缩略语..... 2

4 概述..... 3

5 安全技术要求..... 3

 5.1 身份认证..... 3

 5.2 接入授权..... 3

 5.3 访问控制..... 3

 5.4 数据传输..... 4

 5.5 数据脱敏..... 4

 5.6 数据筛选..... 4

 5.7 攻击防护..... 5

 5.8 安全监测..... 5

 5.9 进退网管理..... 5

 5.10 安全审计..... 6

6 测试方法..... 6

 6.1 身份认证..... 6

 6.2 接入授权..... 7

 6.3 访问控制..... 7

 6.4 数据传输..... 8

 6.5 数据脱敏..... 9

 6.6 数据筛选..... 10

 6.7 攻击防护..... 11

 6.8 安全监测..... 12

 6.9 进退网管理..... 13

 6.10 安全审计..... 14

附 录 A..... 16

前 言

本文件按照GB/T 1.1—2020《标准化工作导则 第1部分 标准化文件的结构和起草规则》的规定起草。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别这些专利的责任。

本文件由中国通信标准化协会提出并归口。

本文件起草单位：中国信息通信研究院、中国电信集团公司、中国移动通信集团有限公司、中国联合网络通信集团有限公司、中讯邮电咨询设计院有限公司、全知科技（杭州）有限责任公司、北京山石网科信息技术有限公司、恒安嘉新（北京）科技股份公司、成都思维世纪科技有限责任公司、上海观安信息技术股份有限公司、亚信科技（成都）有限公司、杭州美创科技有限公司、北京安华金和科技有限公司、北京炼石网络技术有限公司、珠海高凌信息科技股份有限公司、北京亚鸿世纪科技发展有限公司、OPPO广东移动通信有限公司、北京数安行科技有限公司、杭州大拙信息技术有限公司、北京神州绿盟科技有限公司、深圳昂楷科技有限公司、杭州安恒信息技术股份有限公司、郑州信大捷安信息技术股份有限公司、深圳市网安计算机安全检测技术有限公司、贝壳找房（北京）科技有限公司、美的集团股份有限公司。

本文件主要起草人：解伯延、王丹辉、谢玮、陈湑、刘明辉、耿冠和、蔡逆水、江为强、吴连勇、孙宁宁、王首媛、金科、王伟光、赵烨、孟娟、钟志成、谢江、王吉文、唐力、刘玉红、王华飞、刘晓光、瞿宏锋、杨昆霖、王振东、官文兵、张海川、刘为华、黄伟杰、王军军、杨坤。

电信网和互联网应用程序接口数据安全技术要求和测试方法

1 范围

本文件规定了电信网和互联网应用程序接口（API）数据安全的技术要求，并提供了相应测试方法、判定准则等。

本文件适用电信网和互联网API相关的开发者、运营者及专业测评机构开展API数据安全测试工作，为提升API数据安全水平，强化测试能力、健全技术手段提供指引和依据。本文件不适用于操作系统接口、硬件接口。

2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中，注日期的引用文件，仅该日期对应的版本适用于本文件；不注日期的引用文件，其最新版本（包括所有的修改单）适用于本文件。

GB/T 25069 信息安全技术 术语

GB/T 29246 信息技术 安全技术 信息安全管理体系 概述和词汇

GB/T 35273 信息安全技术 个人信息安全规范

3 术语和定义

GB/T 25069、GB/T 29246和GB/T 35273中界定的以及下列术语和定义适用于本文件。

3.1

应用程序接口 application programming interface

一组预先定义好的功能，开发者可通过该功能（或功能的组合）便捷地访问相关服务，而无需关注服务的设计与实现。

[来源：JR/T 0185-2020, 3.1]

3.2

会话令牌 token

交互会话中证明自身的唯一身份标识符，可用于控制用户访问对象及执行相关操作的权限。

3.3

开放应用程序接口 OpenAPI

针对HTTP API的标准的、与编程语言无关的接口规范描述。

3.4
模式 schema

对API的接口和返回数据的类型、结构等信息的规范化描述。

3.5
日志 log

对设备或软件在运行过程中对其状态变化、操作及异常等进行的记录。

3.6
异常行为 abnormal behavior

针对数据所进行的异常的、不符合管理要求的、与预期不符的访问和利用的行为，包括并不限于对数据超频次访问、越权访问、绕行访问、非常规时间访问等。

3.7
重要数据 key data

一旦遭到篡改、破坏、泄露或者非法获取、非法利用，可能危害国家安全、公共利益的数据。

注:重要数据不包括国家秘密和个人信息，但基于海量个人信息形成的统计数据、衍生数据有可能属于重要数据。

4 缩略语

下列缩略语适用于本文件。

ACL	访问控制列表	Access Control Lists
API	应用程序接口	Application Programming Interface
DDoS	分布式拒绝服务	Distributed Denial of Service
LDAP	轻量级目录存取协议	Lightweight Directory Access Protocol
OIDC	开放身份授权	OpenID Connect
oAuth	开放授权协议标准	Open Authorization
RBAC	基于角色的访问控制	Role-Based Access Control
SOAP	简单对象访问协议	Simple Object Access Protocol
SQL	结构化查询语言	Structured Query Language
TLCP	信息安全技术传输层密码协议	Transport Layer Cryptography Protocol
TLS	安全传输层协议	Transport Layer Security
WAF	网络应用防火墙	Web Application Firewall
WSDL	网络服务描述语言	Web Services Description Language
XML	可扩展标记语言	Extensible Markup Language

5 概述

应用程序接口（API）是一组预先定义的功能，通过访问接口可实现不同程序之间数据交互及功能调用。从API主要应用场景及开放对象划分，可将API分为开放（公共）、面向合作方（特定用户）和内部（私有）三类，详见附录A。

本文件从身份认证、接入授权、访问控制、数据传输、数据脱敏、数据筛选、攻击防护、安全监测、进退网管理、安全审计环节针对通过互联网访问、调用的API提出差异化的安全技术要求和相应测试方法，并根据API应用场景及涉及的数据类型给出适用性关系，示例详见附表A。

6 安全技术要求

6.1 身份认证

6.1.1 认证机制

应设置API用户身份认证机制，通过如密钥、令牌、证书、静/动态口令、OIDC等手段实现有效的用户身份验证。

注：用户指API调用方，如网站、应用程序等。

6.1.2 安全策略

API应设置有效的接入、调用策略，包括：

- a) API身份认证机制应具备口令复杂度策略，限制或禁止常见弱口令。
- b) API身份认证机制应具备身份认证操作锁定策略，对错误尝试次数进行限制。
- c) API身份认证机制应具备凭证有效期策略，要求定期对静态身份凭证进行修改。

6.2 接入授权

6.2.1 授权机制

应具备API用户授权机制，并基于不同用户身份分配其可访问的服务、资源及可执行操作。

6.2.2 会话管理

宜具备API访问会话管理机制，当用户会话过期或被放弃后，应及时锁定或注销用户并终止会话。

6.3 访问控制

6.3.1 粗粒度访问控制

应具备针对未授权访问的识别和阻断能力，实现基于如访问时间、访问次数、用户IP等要素的粗粒度API访问控制。

6.3.2 细粒度访问控制

宜通过ACL、RBAC等技术，实现基于如签名、时间戳、黑白名单等机制的细粒度API资源访问控制。

6.3.3 令牌添加变量

应对API会话令牌等重要身份验证凭证进行添加变量操作，以防范重放、彩虹表碰撞等攻击。

6.3.4 二次认证机制

涉及重要数据或个人信息的API，宜部署基于动态口令、OAuth（2.0及以上）等技术的二次认证机制。

6.4 数据传输

6.4.1 请求参数校验

宜部署具备请求参数（如名称、参数类型、取值范围等）校验能力的API管控机制，包括但不限于WAF、API网关、数据层防护工具、代码层过滤配置等。

6.4.2 数据资源安全

宜对API请求参数的规则、配置、URL等进行转义编码，避免关键地址、参数、字段泄露或存在歧义。

6.4.3 安全传输策略

涉及重要数据或个人信息的API，应在数据传输中采用如加密、签名等手段对关键参数、数据内容等进行保护。

6.5 数据脱敏

6.5.1 脱敏能力

涉及重要数据或个人信息等的API，宜部署数据脱敏工具并根据API功能及用户配置相应脱敏策略，以实现返回数据有效脱敏。

6.5.2 脱敏有效性

API返回数据脱敏效果应与脱敏规则一致，确保数据脱敏的有效性、真实性、高效性和多样性。

注：数据脱敏要求可参考电信网和互联网数据脱敏相关标准。

6.6 数据筛选

6.6.1 返回数据筛选

宜根据API功能及数据类型对返回数据类型、格式等进行筛选，避免返回数据量及数据内容超出API设计要求。

6.6.2 差异化管控

宜根据API涉及的数据类型及数据分类分级情况对接口进行梳理，形成差异化管控，如差异化访问控制、身份认证机制、数据传输协议等。

注：数据分类分级相关要求遵守YD/T 3813-2020《基础电信企业数据分类分级方法》和YD/T XXXX-202X《电信网和互联网数据分类分级技术要求与测试方法》中的规定。

6.6.3 重要数据识别

涉及重要数据或个人信息等的API，宜部署管控机制对返回内容进行识别并设置有效的告警、阻断策略。

6.7 攻击防护

6.7.1 自动攻击防护

API应部署自动化的攻击防护机制，包括：

- a) 应具备同一用户或IP地址认证失败重试次数的限制，防范针对API的暴力破解攻击。
- b) 应具备对爬虫或扫描器等的数据爬取行为的监测识别能力，防范针对API的自动化数据爬取。
- c) 应具备对API访问速率和连接数管控机制，防范针对API的DDoS攻击。

6.7.2 基于 API 模式的攻击防护

应基于API模式部署安全防护机制，包括：

- a) 对API请求，应建立基于OpenAPI模式规范的安全防护机制。
- b) 对基于XML SOAP的API请求，宜建立基于WSDL模式规范的安全防护机制。

6.7.3 数据传输防护

应针对API数据传输环节部署安全防护机制，包括：

- a) 应对API远程数据传输采用TLS/TLCP加密技术，确保请求真实性，防范嗅探攻击、数据篡改等。
- b) 宜根据API功能及涉及数据类型通过安全管控工具、系统、平台等实现对数据传输行为的监控，防范非法访问、攻击行为等。

6.7.4 注入攻击防护

应防范针对API的注入漏洞攻击，如通过API参数实现的SQL注入漏洞、命令注入漏洞、LDAP注入漏洞等。

6.8 安全监测

6.8.1 异常行为监测

应形成正常API访问行为基线，针对如高频登陆尝试、爬虫访问、非工作时间访问、访问源IP地址异常、特权账号登陆、访问频次超标、批量下载等异常访问行为进行监测、记录，并阻断高危异常访问。

6.8.2 特权账号监测

宜对API特权用户行为进行监测、记录，防范特权用户滥权操作。

6.8.3 合作方访问监测

宜对API合作方用户异常行为进行监测，防范合作方用户越权操作。

6.9 进退网管理

6.9.1 进网管理

应具备API上线审核机制，确保在满足安全要求的情况下进行审核发布并记录形成API资产清单。

6.9.2 退网管理

应具备API下线审批制度并根据API关联情况进行退网管理，对于具有深度关联的API，宜根据关联层次逐层通知相关API使用方，并设定合理下线时限。

6.10 安全审计

6.10.1 日志记录

API应具备完备的日志记录能力，包括：

- a) 应对API的访问、操作、告警等进行完整的日志记录，日志信息如请求IP、用户名、时间、请求API、请求内容、响应结果等。
- b) 日志宜记录API访问信息，如访问用户IP, 登录令牌，权限级别、访问时间等。
- c) 日志宜记录API操作内容信息，如操作对象、请求方式（POST、PUT）、响应时间等信息。
- d) 日志宜记录API返回结果信息，如返回数据格式、执行成功与否、是否包含操作风险、是否包含重要数据等。

6.10.2 日志审计

应对定期对API日志进行安全审计，确保日志完整性和可用性并形成审计报告。

6.10.3 日志溯源

日志内容应直接或间接含有数据泄露源头、途径、类型、规模等信息，满足对与API相关的数据泄露事件的溯源需求。

7 测试方法

7.1 身份认证

7.1.1 认证机制测试

安全要求	应设置API用户身份认证机制，通过如密钥、令牌、证书、静/动态口令、OIDC等手段实现有效的用户身份验证，防范中间人攻击等安全风险。
预置条件	无
测试方法	a) 查验API是否具备身份认证功能 b) 利用正确及错误的账号口令、令牌等进行身份认证
预期结果	a) API设置了接入身份认证机制 b) 正确身份验证通过，错误身份验证失败
判定准则	上述预期结果均满足判定为符合，其他情况判定为不符合

7.1.2 安全策略测试

安全要求	a) API 身份认证机制应具备口令复杂度策略，限制或禁止常见弱口令。 b) API 身份认证机制应具备身份认证操作锁定策略，对错误尝试次数进行限制。 c) API 身份认证机制应具备凭证有效期策略，要求定期对静态身份凭证进行修改。
预置条件	具备用户身份认知机制
测试方法	a) 查验API是否配置口令复杂度策略，尝试创建不符合复杂度策略的口令 b) 查验API是否配置重试锁定策略，尝试提供错误认证凭证次数超过限定次数 c) 查验API是否配置凭证有效期限策略，尝试试用超过有效期的凭证进行认证
预期结果	a) API 配置了口令复杂度策略，且不符合复杂度策略的口令无法创建 b) API 配置了认证失败锁定策略，且失败认证次数超过阈值后账号锁定 c) API 配置了凭证有效期限策略，且使用超期凭证认证不通过
判定准则	上述预期结果均满足判定为符合，其他情况判定为不符合

7.2 接入授权

7.2.1 授权机制测试

安全要求	应具备API用户授权机制，并基于不同用户身份分配其可访问的服务、资源及可执行操作。
预置条件	部署了API安全管控工具/系统/平台
测试方法	查阅技术文档并登录安全管控工具/系统/平台后台，查验权限管理功能设置，尝试使用低权限用户进行越权操作
预期结果	a) 具备权限管理功能，权限分配合理，且越权操作无法执行
判定准则	上述预期结果均满足判定为符合，其他情况判定为不符合

7.2.2 会话管理测试

安全要求	宜具备API访问会话管理机制，当用户会话过期或被放弃后，应及时锁定或注销用户并终止会话。
预置条件	无
测试方法	a) 查验API会话管理机制及超时阈值设置 b) 创建API会话后，不进行操作，等待超出超时阈值
预期结果	a) API具备会话管理机制 b) 等待超时后会话自动终止
判定准则	上述预期结果均满足判定为符合，其他情况判定为不符合

7.3 访问控制

7.3.1 粗粒度访问控制测试

安全要求	应具备针对未授权访问的识别和阻断能力，实现基于如访问时间、访问次数、用户IP等要素的粗粒度API访问控制。
预置条件	部署了API安全管控工具/系统/平台

测试方法	a) 查阅技术文档并登录安全管控工具/系统/平台后台，查验未授权访问的识别和封堵功能设置 b) 尝试通过公开或测试账号，模拟不同时间、次数、IP的访问请求，记录访问控制策略有效性
预期结果	访问控制策略所禁止的时间、次数、IP的访问请求被记录 and 封堵
判定准则	上述预期结果均满足判定为符合，其他情况判定为不符合

7.3.2 细粒度访问控制测试

安全要求	宜通过ACL、RBAC等技术，实现基于如签名、时间戳、黑白名单等机制的细粒度API资源访问控制。
预置条件	部署了API安全管控工具/系统/平台
测试方法	a) 查阅技术文档并登录安全管控工具/系统/平台后台，查验基于ACL、RBAC等技术的访问控制设置 b) 尝试构造测试账号，模拟各类签名、时间戳、黑白名单访问请求，记录访问控制策略有效性
预期结果	不符合预设条件的签名、时间戳、黑白名单的请求被记录 and 封堵
判定准则	上述预期结果均满足判定为符合，其他情况判定为不符合

7.3.3 令牌添加变量测试

安全要求	应对API会话令牌等重要身份验证信息进行添加变量，防范重放、彩虹表碰撞等攻击。
预置条件	API使用令牌机制进行身份认证
测试方法	a) 访问研发、运营人员，查阅相关技术文档，记录加盐算法使用情况 b) 尝试构造测试账号，进行多次连续请求，比对分析令牌信息
预期结果	连续请求令牌信息存在随机差异
判定准则	上述预期结果均满足判定为符合，其他情况判定为不符合

7.3.4 二次认证机制测试

安全要求	涉及重要数据或个人信息的API，宜部署基于动态口令、OAuth2.0（及以上）等技术的二次认证机制。
预置条件	具备二次认证功能
测试方法	a) 访问研发、运营人员，查阅相关技术文档，查验二次认证策略部署情况 b) 尝试构造测试账号，进行认证绕过、重放攻击等模拟测试，记录并观察二次认证机制有效性
预期结果	无法绕过认证机制，重复登录请求被拒绝，二次认证功能完整可用
判定准则	上述预期结果均满足判定为符合，其他情况判定为不符合

7.4 数据传输

7.4.1 请求参数校验测试

安全要求	宜部署具备请求参数（如名称、参数类型、取值范围等）校验能力的API管控机制，包括但不限于WAF、API网关、数据层防护工具、代码层过滤配置等。
------	---

预置条件	无
测试方法	a) 登录安全管控工具/系统/平台后台，查验安全规则或安全策略并记录API请求参数设置 b) 利用自动化工具或测试脚本模拟传输请求，分析服务端返回参数值
预期结果	API传输参数管理策略已开启，返回参数与预设策略一致
判定准则	上述预期结果均满足判定为符合，其他情况判定为不符合

7.4.2 数据资源安全测试

安全要求	宜对API请求参数的规则、配置、URL等进行转义编码，避免关键地址、参数、字段泄露或存在歧义。
预置条件	部署了API安全管控工具/系统/平台
测试方法	a) 查阅API资产明细及相关技术文档 b) 查验API目录名称、数据标识、URL等信息是否进行了转义编码
预期结果	API配置信息进行了转义编码，或未发现明文的目录名称、数据标识、URL等信息
判定准则	上述预期结果均满足判定为符合，其他情况判定为不符合

7.4.3 安全传输策略测试

安全要求	涉及重要数据或个人信息的API，应在数据传输中采用如加密、签名等手段对关键参数、数据内容等进行保护。
预置条件	API涉及重要数据或个人信息
测试方法	a) 访问研发、运营人员，查阅相关技术文档，记录加密机制与签名算法等配置、部署情况 b) 抓取API数据传输流量，识别未加密、加密无效、未签名、签名验证无效等情况并分析测试结果
预期结果	无重要数据或个人信息明文传输，签名验证机制有效且为受信任机构颁发的证书
判定准则	上述预期结果均满足判定为符合，其他情况判定为不符合

7.5 数据脱敏

7.5.1 脱敏能力测试

安全要求	涉及重要数据或个人信息等的API，宜部署数据脱敏工具并根据API功能及用户配置相应脱敏策略，以实现返回数据有效脱敏。
预置条件	部署了脱敏工具或具有脱敏功能的API安全管控工具/系统/平台
测试方法	a) 使用管理员账号，登录脱敏工具或API安全管控工具/系统/平台后台，查验并记录返回数据脱敏功能相关配置 b) 判断是否针对API数据及用户类型设置了合理的数据脱敏规则
预期结果	API具备数据脱敏能力并设置了有效的脱敏规则
判定准则	上述预期结果均满足判定为符合，其他情况判定为不符合

7.5.2 脱敏有效性测试

安全要求	API返回数据脱敏效果应与脱敏规则一致，确保数据脱敏的有效性、真实性、高效性和多样性。
预置条件	API具备数据脱敏能力并设置了有效的脱敏规则
测试方法	a) 尝试构造不同类型的用户请求并记录返回数据 b) 查验返回数据是否经脱敏处理，并对比脱敏后数据内容是否与脱敏规则一致
预期结果	API返回数据经脱敏处理，脱敏内容与脱敏规则一致
判定准则	上述预期结果均满足判定为符合，其他情况判定为不符合

7.6 数据筛选

7.6.1 返回数据筛选测试

安全要求	宜根据API功能及数据类型对返回数据类型、格式等进行筛选，避免返回数据量及数据内容超出API设计要求。
预置条件	无
测试方法	a) 查验API资产清单及相关技术文档，核验返回数据类型及格式要求等信息 b) 尝试模拟用户请求并抓取API返回数据包内容，核验返回数据类型、格式、数据量是否与预设数据返回要求一致
预期结果	API返回数据类型、数据量等未超出其设计要求
判定准则	上述预期结果均满足判定为符合，其他情况判定为不符合

7.6.2 差异化管理控测试

编号	5.6.2
安全要求	宜根据API涉及的数据类型及数据分类分级情况对接口进行梳理，形成差异化管理控，如差异化访问控制、身份认证机制、数据传输协议等。
预置条件	部署了API安全管控工具/系统/平台
测试方法	查阅API资产清单，访问开发、运维人员，登录安全管控工具/系统/平台后台，查验接口安全防护策略差异化配置
预期结果	API资产根据其功能及涉及数据进行了分类，并根据后台数据分级情况，对API实施了差异化管理控
判定准则	上述预期结果均满足判定为符合，其他情况判定为不符合

7.6.3 重要数据识别测试

安全要求	涉及重要数据或个人信息等的API，宜部署管控机制对返回内容进行识别并设置有效的告警、阻断策略。
预置条件	部署了API安全管控工具/系统/平台，具备返回数据筛选能力
测试方法	a) 查阅API资产清单，并登录安全管控平台/系统后台，查验数据筛选、识别功能策略 b) 尝试构造测试API，模拟返回超出策略阈值的重要数据、个人信息数据，查验安全管控机制是否有效识别，并进行告警\阻断、日志记录等
预期结果	API管控平台数据识别策略合理，可识别API超范围返回重要数据、个人信息等数据情况，并进行及时处理
判定准则	上述预期结果均满足判定为符合，其他情况判定为不符合

7.7 攻击防护

7.7.1 自动攻击防护测试

安全要求	a) 应具备同一用户或IP地址认证失败重试次数的限制，防范针对API的暴力破解攻击。 b) 应具备对爬虫或扫描器等的数据爬取行为的监测识别能力，防范针对API的自动化数据爬取。 c) 应具备对API访问速率和连接数管控机制，防范针对API的DDoS攻击。
预置条件	部署了API安全管控工具/系统/平台
测试方法	a) 使用漏洞扫描工具暴力破解模块，针对API接口进行认证尝试攻击，查验API安全管控系统日志中是否含攻击行为记录，攻击流量是否被阻塞 b) 构造测试接口爬虫脚本，通过API接口进行数据爬取，查验API安全管控系统日志中是否包含数据爬取行为记录，数据爬取请求是否被阻塞 c) 构造DoS脚本对API接口进行快速多次访问检查，查验日志中是否包含DoS攻击记录，攻击流量是否被限制或阻塞
预期结果	a) 日志中有攻击记录，认证攻击的后续尝试被阻断 b) 日志中有爬虫行为记录，爬虫连接可以被阻断。 c) 日志中有DoS攻击记录，频率超阈值的访问被丢弃或阻断。
判定准则	上述预期结果均满足判定为符合，其他情况判定为不符合

7.7.2 基于API模式的攻击防护测试

安全要求	a) 对API请求，应建立基于OpenAPI模式规范的安全防护机制。 b) 对基于XML SOAP的API请求，宜建立基于WSDL模式规范的安全防护机制
预置条件	无
测试方法	a) 构造违反Open API模式的API请求，查验请求是否记入日志并被阻塞 b) 构造违反WSDL模式的API请求，查验请求是否记入日志并被阻塞
预期结果	构造的API请求被记入日志，且请求被阻断。
判定准则	上述预期结果均满足判定为符合，其他情况判定为不符合

7.7.3 数据传输防护测试

安全要求	a) 应对API远程数据传输采用TLS/TCP加密技术，确保请求真实性，防范嗅探攻击、数据篡改等。 b) 宜根据API功能及涉及数据类型部署安全管控机制，实现对数据传输行为的监控，防范非法访问、攻击行为等。
预置条件	a) 支持TLS1.2及以上版本/TCP b) 部署了API安全管控工具/系统/平台
测试方法	a) 构造API数据传输，并进行流量分析、抓包测试 b) 尝试部署商用或开源工具构造模拟的特定信息泄漏场景或高危行为，查验数据泄露场景是否被查出、高危行为是否被阻断
预期结果	a) 未抓取到明文数据包 b) 信息泄露场景可被检出，数据批量导出、修改等高危行为被阻断
判定准则	上述预期结果均满足判定为符合，其他情况判定为不符合

7.7.4 注入攻击防护测试

安全要求	应防范针对API的注入漏洞攻击，如通过API参数实现的SQL注入漏洞、命令注入漏洞、LDAP注入漏洞等。
预置条件	部署了API安全管控工具/系统/平台
测试方法	部署商业或开源的Web漏洞扫描工具，构造测试用SQL注入、命令注入等脚本，并查验管控机制后台，分析测试脚本命令是否被阻断
预期结果	测试脚本命令无法执行，注入攻击尝试被阻断且有告警、日志记录
判定准则	上述预期结果均满足判定为符合，其他情况判定为不符合

7.8 安全监测

7.8.1 异常行为监测能力测试

安全要求	应形成正常API访问行为基线，针对如高频登陆尝试、爬虫访问、非工作时间访问、访问源IP地址异常、特权账号登陆、访问频次超标、批量下载等异常访问行为进行监测、记录，并阻断高危异常访问。
预置条件	部署了API安全管控工具/系统/平台
测试方法	a) 查阅相关技术文档、资产清单，并访谈相关开发运维人员，查验是否形成安全有效的正常行为基线 b) 构造测试脚本，尝试在非工作时间内访问API，查验管控机制是否产生非访问行为进行告警 c) 构造测试脚本，尝试短时间内进行大量访问操作，查验管控机制是否产生高频访问告警 d) 构造测试爬虫工具，模拟爬取API，查验管控机制是否进行有效告警，是阻断高危异常访问 e) 构造测试环境，尝试通过代理模拟异常IP地址访问行为，查验管控机制是进行有效告警 f) 构造测试脚本，模拟短时间内大量查询、下载等行为，查验管控机制是否对大量数据访问、操作进行告警及阻断
预期结果	建立了有效的安全基线，安全管控机制可有效识别、阻断、记录超出基线阈值的异常行为
判定准则	上述预期结果均满足判定为符合，其他情况判定为不符合

7.8.2 特权账号监测能力测试

安全要求	宜对API特权用户行为进行监测、记录，防范特权用户滥权操作。
预置条件	部署了API安全管控工具/系统/平台
测试方法	a) 查阅相关文档并访问开发、运维人员，核验API是否存在特权账号及相应管控机制 b) 尝试构造高权限账号进行模拟访问、操作（如sysadmin、admin、test等），查验安全管控系统是否具备特权账号监测能力
预期结果	存在高权限用户管控机制，可识别并记录高权限账号的API访问行为
判定准则	上述预期结果均满足判定为符合，其他情况判定为不符合

7.8.3 合作方访问监测能力测试

安全要求	宜对API合作方用户异常行为进行监测，防范合作方用户越权操作。
预置条件	部署了API安全管控工具/系统/平台
测试方法	a) 查阅相关文档并访问开发、运维人员，核验API是否存在合作方用户及相应管控机制 b) 尝试模拟合作方用户数据访问行为，构造短时间内高频操作等异常行为，查验管控机制是否记录合作方访问行为
预期结果	存在合作方用户管控机制，可识别并记录合作方用户的API访问行为
判定准则	上述预期结果均满足判定为符合，其他情况判定为不符合

7.9 进退网管理

7.9.1 进网管理测试

安全要求	应具备API上线审核机制，确保在满足安全要求的情况下进行审核发布并记录形成API资产清单。
预置条件	无
测试方法	a) 查阅相关文档并访问开发、运维人员，核验是否建立了API上线审批机制并形成了API资产清单 b) 尝试模拟API上线申请，查验审核通过后API资产清单是否更新并显示新上线接口
预期结果	建立了API上线审批机制并形成了API资产清单
判定准则	上述预期结果均满足判定为符合，其他情况判定为不符合

7.9.2 退网管理测试

安全要求	应具备API下线审批制度并根据API关联情况进行退网管理，对于具有深度关联的API，应根据关联层次逐层通知相关API使用方，并设定合理下线时限。
预置条件	部署了API管控工具/系统/平台
测试方法	a) 查阅相关文档并访问开发、运维人员，核验是否建立了API下线审批管理机制 b) 构造测试API并登录安全管控系统并尝试提交其下线申请，查看下线API的关联情况记录 c) 登录API调用方通知接收渠道，查验是否收到通知并查验限定时间内API是否完成下线
预期结果	下线管理机制有效制并对API调用方进行通知
判定准则	上述预期结果均满足判定为符合，其他情况判定为不符合

7.10 安全审计

7.10.1 日志记录测试

安全要求	a) 应对API的访问、操作、告警等进行完整的日志记录，日志信息如请求IP、用户名、时间、请求API、请求内容、响应结果等。 b) 日志宜记录API访问信息，如访问用户IP, 登录令牌，权限级别、访问时间等。
------	---

	c) 日志宜记录API操作内容信息，如操作对象、请求方式（POST、PUT）、响应时间等信息。 日志宜记录API返回结果信息，如返回数据格式、执行成功与否、是否包含操作风险、是否包含重要数据、个人信息数据等。
预置条件	部署了API管控工具/系统/平台
测试方法	a) 登录服务器或API管控系统，检查是否具备日志记录管理功能，并留存了API日志记录 b) 遍历测试周期内生成的API日志内容并进行比对分析
预期结果	a) 服务器或API管理工具具备日志记录功能，并留存了日志记录 b) API日志内容包含访问信息、操作内容及返回结果，与测试周期内操作一致
判定准则	上述预期结果均满足判定为符合，其他情况判定为不符合

7.10.2 日志审计检测

安全要求	应对定期对API日志进行安全审计，确保日志完整性和可用性并形成审计报告。
预置条件	管控工具/系统/平台具备API日志记录功能
测试方法	a) 查阅API审计策略及相关制度文件并对日志审计负责人员进行访谈 b) 查阅日志审计报告，并比对日志记录与报告内容
预期结果	有定期的日志审计制度与相关负责人且留存有定期API日志审计报告，报告内容完整、真实
判定准则	上述预期结果均满足判定为符合，其他情况判定为不符合

7.10.3 日志溯源测试

安全要求	日志内容应直接或间接含有数据泄露源头、途径、类型、规模等信息，满足对与API相关的数据泄露事件的溯源需求。
预置条件	管控工具/系统/平台具备API日志记录功能
测试方法	a) 利用日志记录追踪API数据操作源头、途径和类型 b) 查验日志功能是否可记录完整的API数据泄露证据
预期结果	通过API日志可追踪到数据泄露的源头、途径、类型、规模并留存完整证据
判定准则	上述预期结果均满足判定为符合，其他情况判定为不符合

附录A
(资料性)

安全要求适用 API 类型示例

从 API 主要应用场景及开放对象划分，可将 API 分为开放（公共）、面向合作方（特定用户）和内部（私有）三类：

- a) 开放 API 指访问者不需要与 API 提供者建立合作关系，且面向公网开放，允许公共访问的 API。
- b) 面向合作方 API 指用以与外部合作伙伴、用户等进行数据交互和系统集成的 API。
- c) 内部 API 指仅在组织内部使用，用来协调、连通组织内不同系统、环境、应用等的 API。

表 A.1 给出了本文件提出的数据安全要求与不同 API 类型的适用性关系示例。

表 A.1 安全要求适用 API 类型示例

章节	要求	开放 API	面向合作方 API	内部 API
7.1 身份认证	认证机制	×	√	√
	安全策略	×	√	√
7.2 接入授权	授权机制	○	√	√
	会话管理	○	○	○
7.3 访问控制	粗粒度访问控制	○	√	√
	细粒度访问控制	○	√	√
	令牌添加变量	○	√	√
	二次认证	×	○	○
7.4 数据传输	请求参数校验	○	○	○
	数据资源安全	√	√	√
	安全传输策略	×	√	√
7.5 数据脱敏	脱敏能力	×	√	√
	脱敏有效性	×	√	√
7.6 数据筛选	数据质量控制	○	√	√
	差异化管控	√	√	√
	重要数据识别	○	√	√
7.7 攻击防护	自动攻击防护	○	√	√
	基于 API 模式攻击防护	○	○	○
	数据传输防护	○	○	○
	注入攻击防护	√	√	√
7.8 安全监测	异常行为监测能力	○	○	○
	特权账号监测能力	×	○	○
	合作方访问监测能力	×	○	○
7.9 进退网管理	进网管理	√	√	√
	退网管理	√	√	√
7.10 安全审计	日志记录	√	√	√
	日志审计	√	√	√

	日志溯源	○	√	√
--	------	---	---	---

注：表内符号“√”代表应具备，“○”代表宜具备，“×”代表不适用。